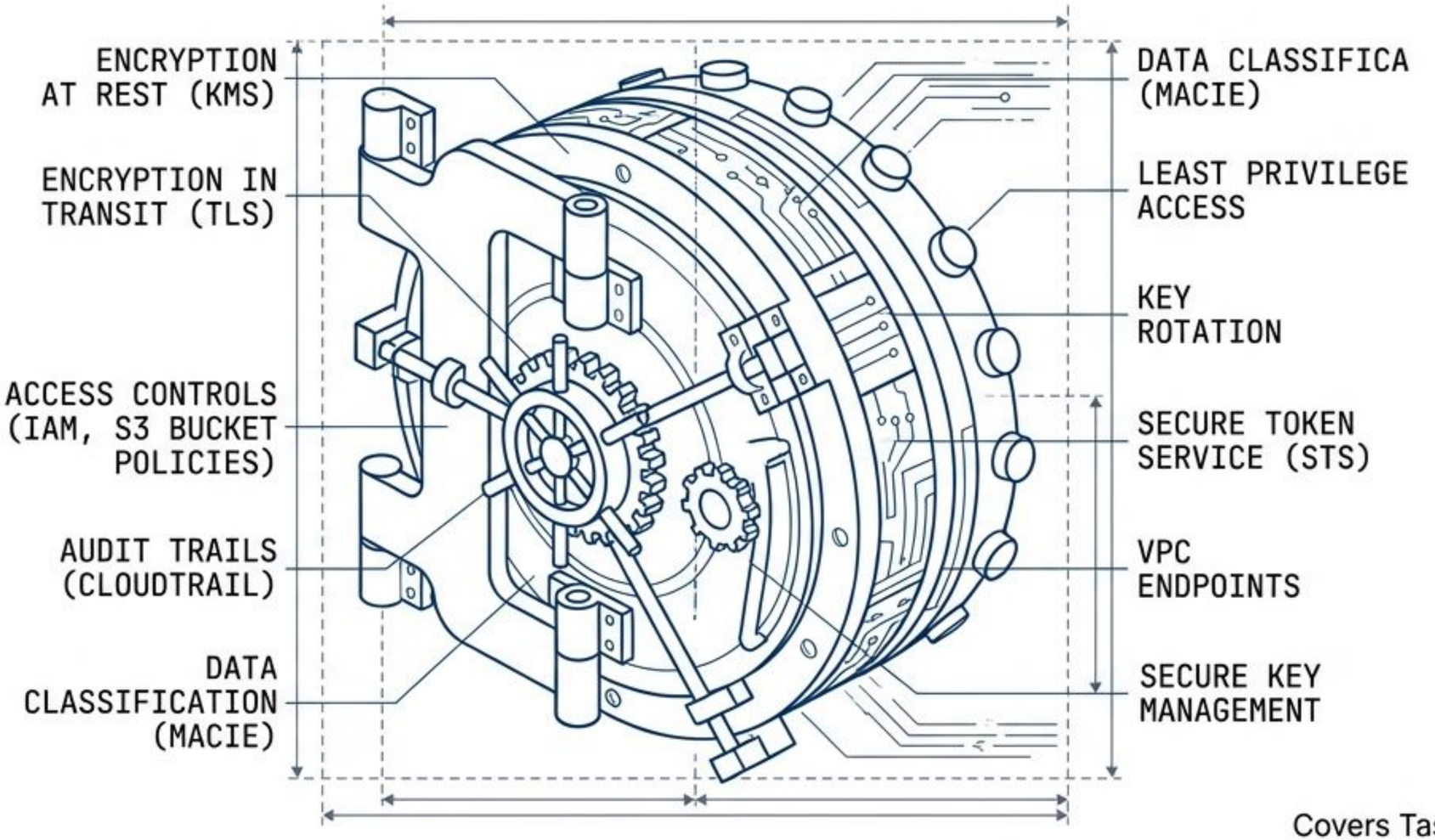
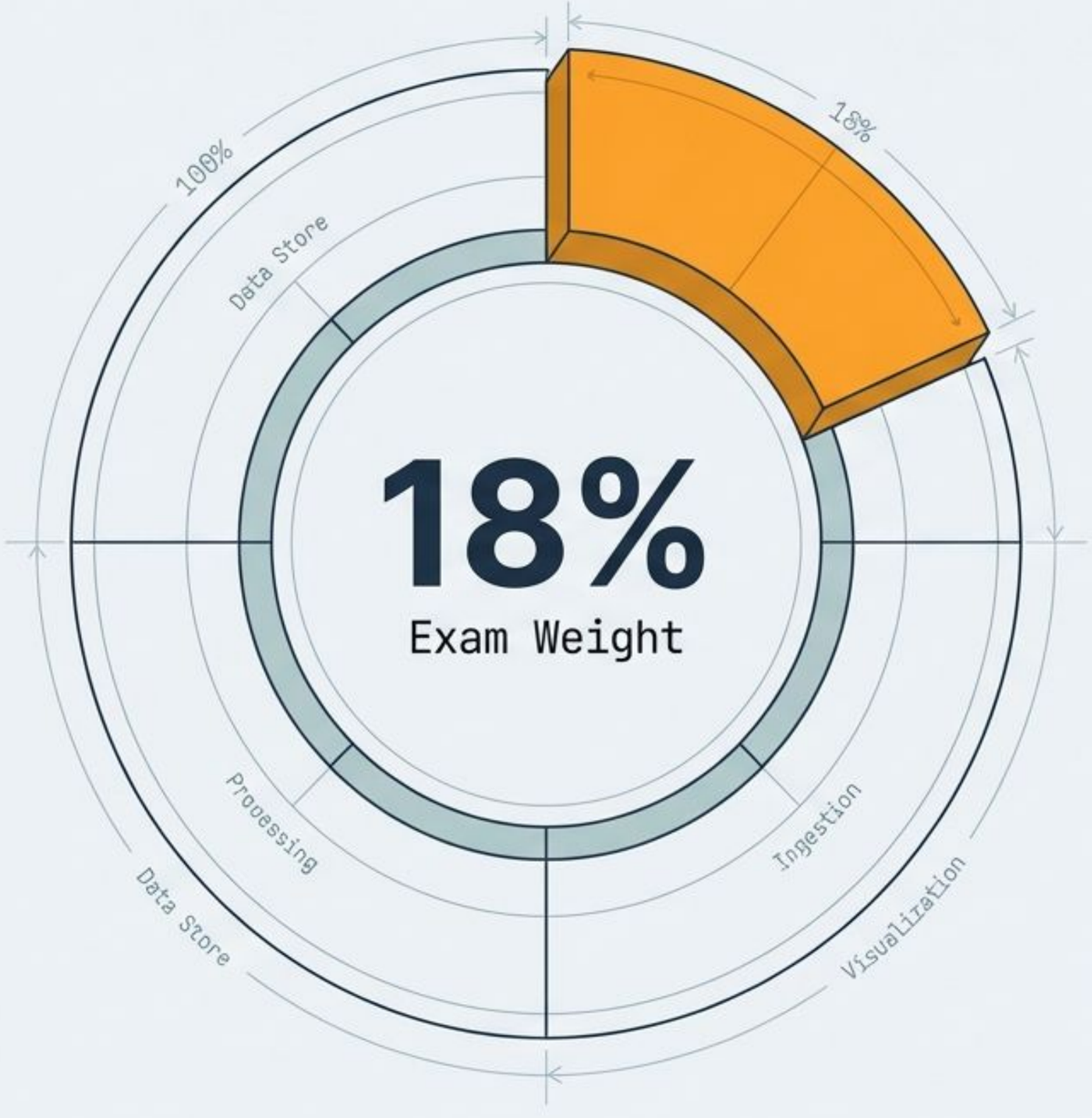
Domain 4: Data Security and Governance

AWS Data Engineer Associate (DEA-C01) Review



Covers Task Statements 4.1 – 4.5

NotebookLM



The 5 Task Statements

1. Authentication (IAM, VPC, Credentials)

2. Authorization (Access Controls, Lake Formation)

3. Encryption & Masking (KMS, Anonymization)

4. Auditing & Logging (CloudTrail, Monitoring)

5. Privacy & Governance (PII, Sovereignty)

Insight: Securing the pipeline is not an afterthought—it represents nearly **1/5th** of your certification score.

NotebookLM

Authentication & Identity

Principals

Workforce
(SSO/Identity Center)

Machine
(IAM Roles)

- IAM Principals: Users, Groups, Roles
- Use AWS IAM Identity Center for centralized workforce access
- Use IAM Roles for service-to-service access (e.g., Lambda accessing S3)

Credential Management

Never hardcode credentials. Use AWS Secrets Manager to rotate and retrieve database credentials programmatically.

Exam Tip: Distinguish between Password-based, Certificate-based, and Role-based auth.

NotebookLM

POLICY LOGIC: THE ACCESS POINT HANDSHAKE

S3 ACCESS POINT POLICY

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": { "AWS": "*" },
      "Action": "*",
      "Resource": [ "Bucket ARN", "Bucket ARN/*"],
      "Condition": {
        "StringEquals": { "s3:DataAccessPointAccount":
"Bucket owner's account ID" }
      }
    }
  ]
}
```

→ ✓ →

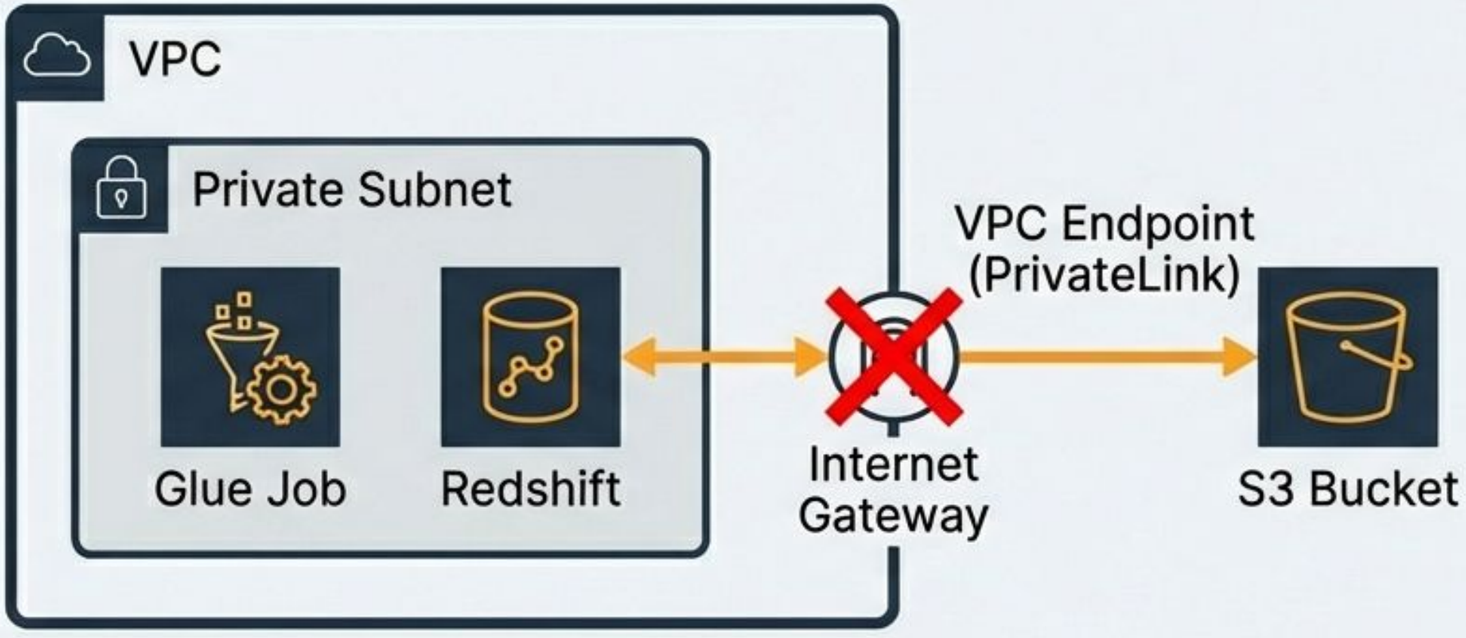
S3 BUCKET POLICY

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::123456789012:user/Julie"
      },
      "Action": ["s3:GetObject", "s3:PutObject"],
      "Resource": "arn:aws:s3:::DOC-EXAMPLE-
BUCKET1/Julie/*"
    }
  ]
}
```

CRITICAL RULE: For access to succeed via an Access Point, BOTH the Access Point Policy AND the underlying Bucket Policy must explicitly grant the request.

NotebookLM

Network Boundaries

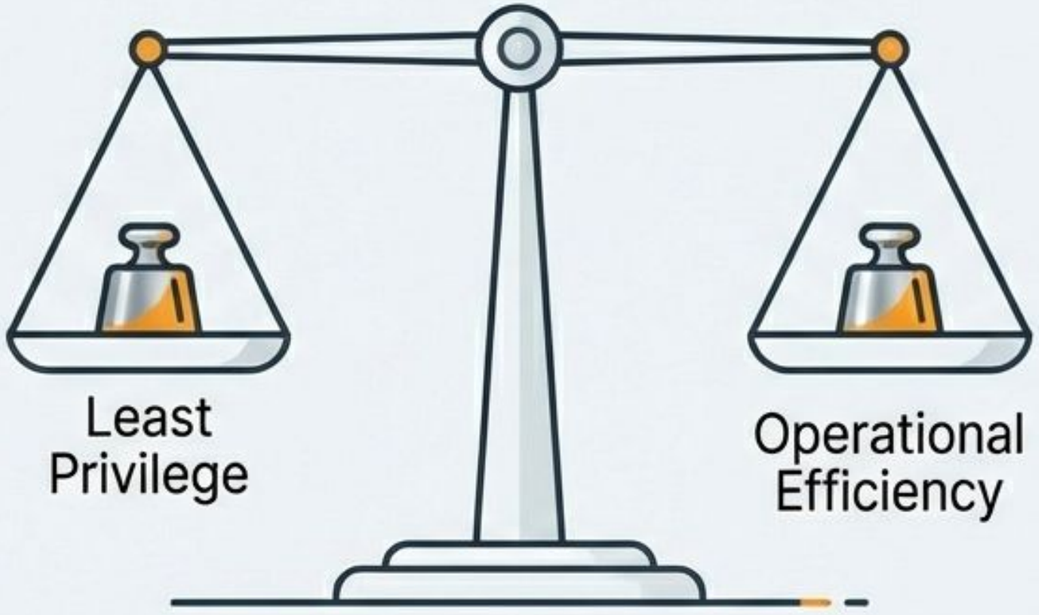


VPC Security Controls:
- Security Groups: Stateful firewalls (Instance level)
- NACLs: Stateless traffic filters (Subnet level)

Private Connectivity:
- Use VPC Endpoints (AWS PrivateLink) to keep traffic between AWS services off the public internet.
- Critical for compliance and latency.

NotebookLM

Authorization Mechanics



Policy Types

- Identity-Based: What I can do (Attached to User/Role)
- Resource-Based: Who can access me (Attached to S3 Bucket/Queue)

Access Models

- RBAC (Role-Based): Permissions via job function
- ABAC (Attribute-Based): Permissions via tags (Project = Blue)

Key Principle

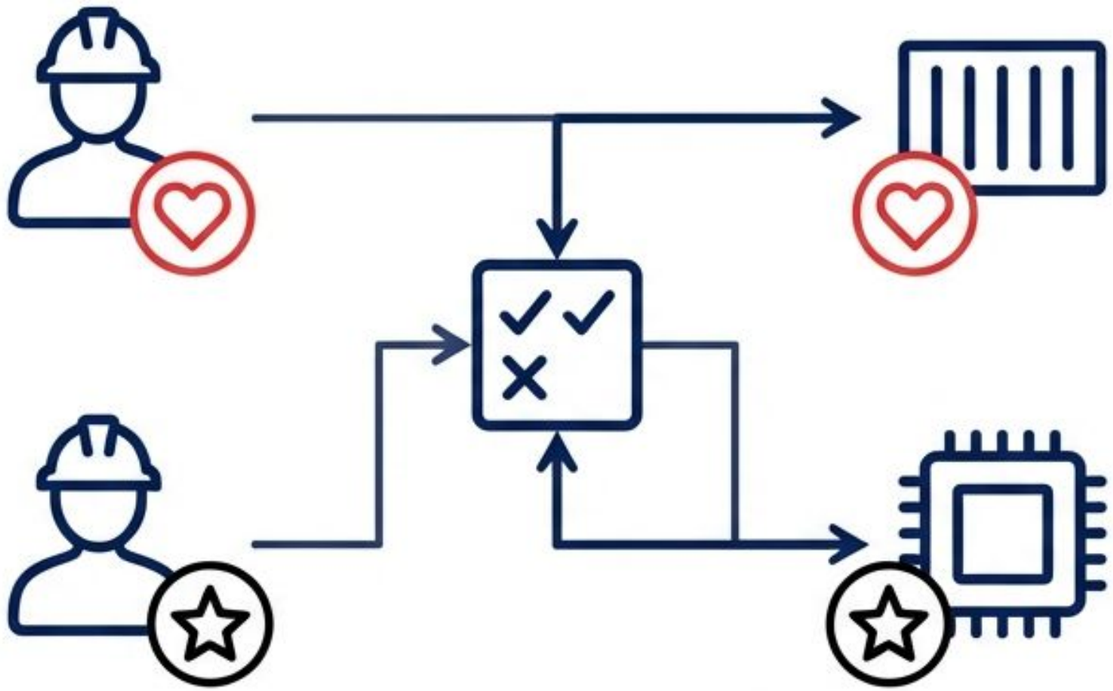
Start with zero access. Grant only what is necessary, only for for the time needed.

NotebookLM

SCALING AUTHORIZATION (RBAC VS. ABAC)

RBAC (ROLE-BASED)

Static.
Based on job function.
Hard to scale.



Access is granted only when Principal Tag matches Resource Tag (e.g., Project = Heart).

ABAC (ATTRIBUTE-BASED)

Dynamic.
Based on matching tags.
Highly scalable.

NotebookLM

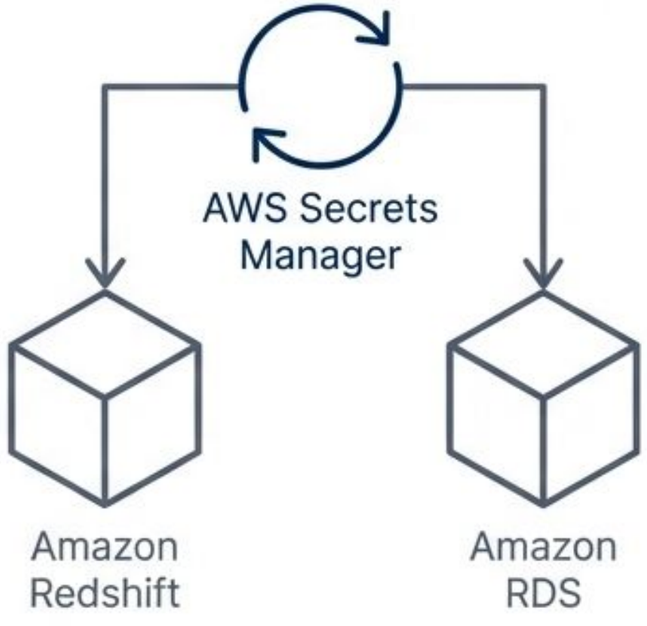
Database Security: Redshift & Secrets Manager

Warning

```
ERROR: user 'username'
can't be dropped
because the user owns
some object.
```

- **The Drop User Trap:** You cannot drop a user if they own objects (tables/views) or have active privileges.
- **Resolution:** Transfer ownership or revoke privileges first.
- **Reference:** See the specific Redshift scenario text.

Credential Rotation



Automate credential rotation. Use Lambda for custom rotation logic if needed.

NotebookLM

The Governance Hub: **AWS Lake Formation**

The Paradigm Shift

- **Old Way**: Coarse-grained IAM S3 Bucket Policies (All or Nothing).
- **New Way**: Fine-grained DBMS-style GRANT/REVOKE permissions.

Hybrid Access Mode

- Allows simultaneous use of IAM/S3 permissions and Lake Formation permissions.
- Enables gradual migration to governed tables.

NotebookLM

AWS LAKE FORMATION

Fine-Grained Access Control (FGAC)

Admin View

Clean architectural border

ID	Name	Salary	Region
101	Alice	$120,000	EU
102	Bob	$95,000	US
103	Charlie	$145,000	APAC
104	David	$88,000	US

Analyst View (Restricted)

Subtitless data screen contoı border

ID	Name	Salary	Region
		[redacted]	
102	Bob	[redacted]	US
103	Charlie	[redacted]	APAC
104	David	[redacted]	US

Column-Level Security: Sensitive data hidden.

Row-Level Security: Data fiiltered based on attributes (e.g., Region != 'EU').

LF-Tags for Scaling

- Assign LF-Tags to resources (e.g., Tag: Sensitivity=High).
- Grant permissions to Principals based on Tags, not individual resource names.

> "LF-Tags make sure that data governance can be scaled easily."

NotebookLM

Data Encryption (At Rest)

SSE-S3

- **Managed Keys:** S3 handles key creation and rotation.
- **Pros:** Simplest, transparent, no extra cost.
- **Cons:** No audit trail of key usage.

SSE-KMS

- **AWS KMS Keys:** Integration with KMS service.
- **Pros:** Audit trail (CloudTrail), separation of duties, key rotation control.

Cost Tip: "Use S3 Bucket Keys to reduce KMS API costs by up to 99%."

SSE-C

- **Customer Provided Keys:** You hold the key.
- **Pros:** Maximum control.
- **Cons:** You must manage key storage; if you lose the key, data is lost.

NotebookLM

Encryption in Transit & Key Management

Data in Motion

- **TLS/SSL** is standard for AWS services (e.g., Kinesis Firehose, MSK).
- Ensures data cannot be intercepted on the wire.

KMS Key Rotation

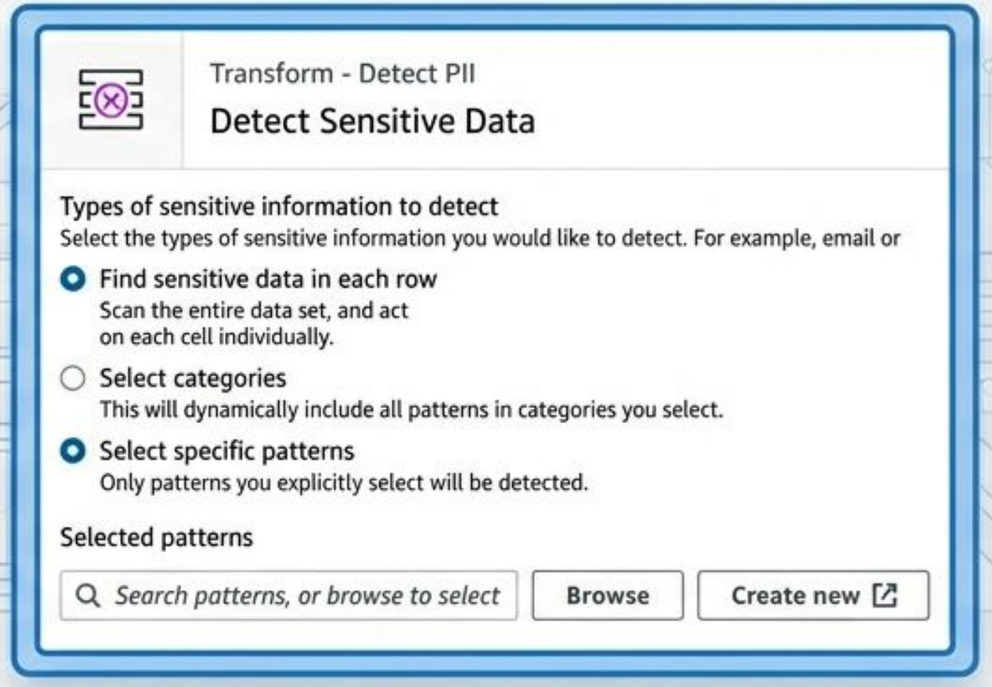
Key Management (KMS)

- **Automatic Rotation:** AWS rotates the backing key material annually.
- **Key Policies:** The primary mechanism to control who can use the key to encrypt/decrypt.

📙 **Exam Note:** "For MSK, if in-transit encryption adds too much latency/overhead, it can be disabled (though not recommended for sensitive data)."

NotebookLM

Data Privacy: Identification & Masking



1. Identification:

- **Amazon Macie:** ML-powered discovery of PII in S3 buckets.

2. Transformation (Remediation):

- **AWS Glue ETL:** 'Detect Sensitive Data' transform.
- **Actions:** Redact, Mask, or Hash PII during the pipeline execution.

NotebookLM

Service Spotlight: Redshift & MSK

Amazon Redshift

Cluster
↓
Database
↓
Schema
↓
Table
↓
Row/Column

- Dynamic Data Masking: Obfuscates data at query time without changing the stored data.
- Redshift Spectrum: Uses account default KMS key for S3 SSE.

Amazon MSK (Kafka)

- Authentication:
  - IAM Access Control
  - SASL/SCRAM
  - mTLS
- Encryption:
  - At-rest (EBS volumes)
  - In-transit (TLS)

NotebookLM

Auditing & Monitoring

- **CloudTrail:** The "Who did what?"' engine. Records API calls (including Lake Formation audits).
- **CloudWatch Logs:** Application logs and error tracking.
- **S3 Access Logs:** Detailed record of requests made to a bucket (requester, time, action).

NotebookLM

Compliance & Data Sovereignty

- **AWS Config:** Monitor and enforce rules (e.g., "S3 buckets must be encrypted").
- **Data Sovereignty:** GDPR and other laws often require data to stay within specific geographic borders.
- **Strategy:** Prevent backups or replication to disallowed AWS Regions.

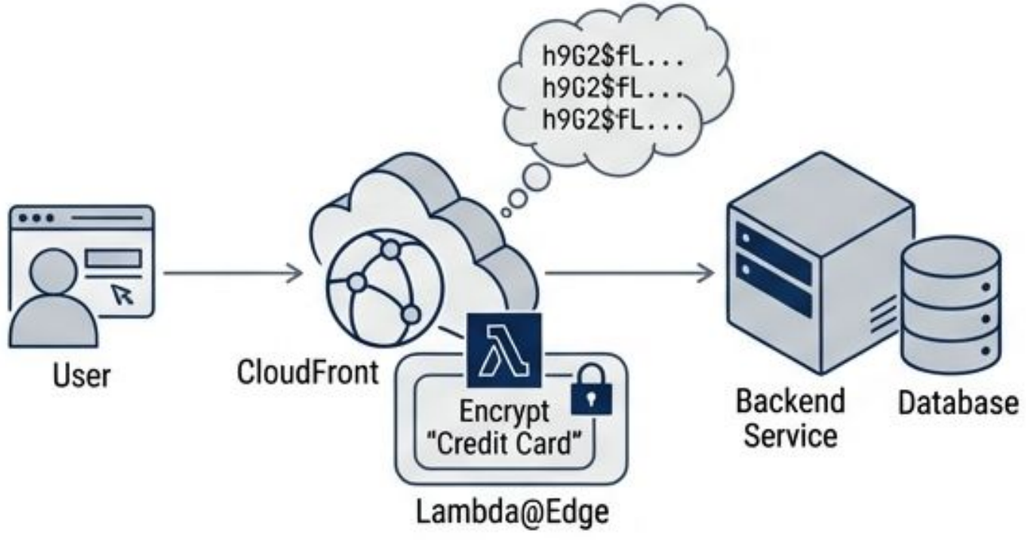
NotebookLM

Sovereignty & Governance at Scale

Data Sovereignty & Edge Protection

Field-Level Encryption: Encrypt sensitive fields (e.g., Credit Card) at the edge using CloudFront + Lambda@Edge.

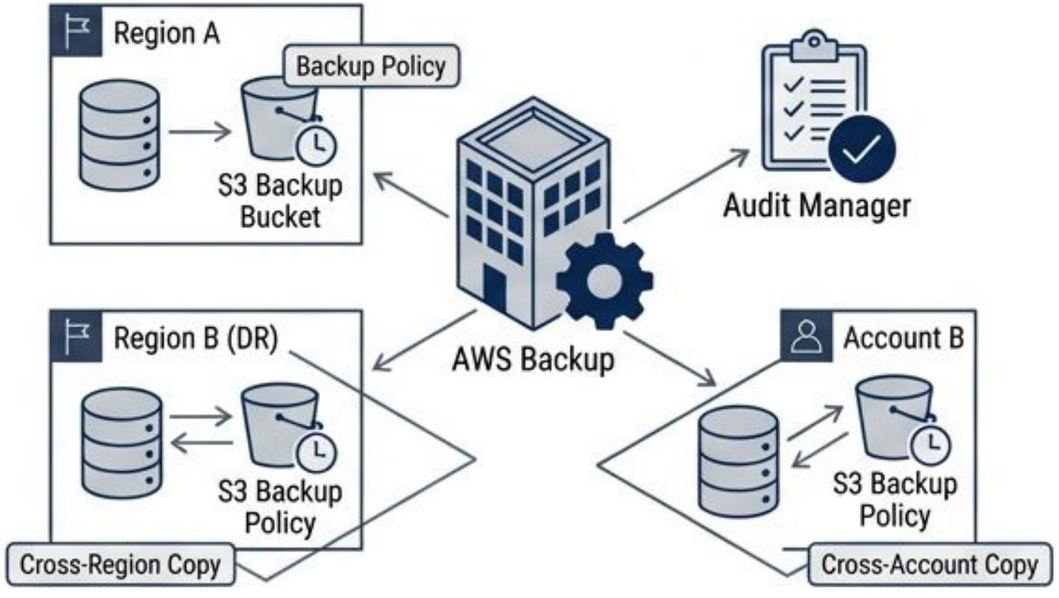
Benefit: Backend never sees plaintext.



Backup Compliance

AWS Backup: Centralized policy-based backups.

- **Key Features:** Cross-Region Copy (Disaster Recovery), Cross-Account Copy, Audit Manager integration.



NotebookLM

Scenario Challenge: Reducing Data Leakage Risk

A company wants to improve its data lake and allow a broader range of access to the data. Because of this work, the company identifies an increased risk of data leakage. A data engineer must implement a solution that reduces these risks. The solution must ensure the privacy of customer data and must comply with data protection laws. Which solution will meet these requirements?

A Use Amazon Macie to identify sensitive data. Use AWS Glue Studio to transform and mask the findings.

B Use AWS CloudTrail to monitor and log all API activity.

C Use AWS Config to enforce security best practices.

D Use Amazon Athena to perform real-time monitoring.

NotebookLM

Domain 4 Summary

1. **Identity:** Centralize workforce identity; never hardcode credentials (Secrets Manager).
2. **Access:** Augment IAM with Lake Formation for fine-grained, scalable governance (LF-Tags).
3. **Encryption:** Encrypt everywhere. Use Bucket Keys to save money on KMS.
4. **Privacy:** Use Macie to find PII and Glue to mask it.
5. **Audit:** If it isn't in CloudTrail, it didn't happen.

Secure the pipeline, pass the domain.

NotebookLM